

Root Admin Governance Policy

Organization: Chronix | Status: Draft | Version: 1.0

1) Purpose

Root Admin exists as a break-glass platform authority for security incidents, account recovery, and critical maintenance. It is not for day-to-day operations.

2) Role Definition

- **Role name:** Root Admin
- **Authority:** Unrestricted access across all modules, records, and administrative controls
- **Scope:** Platform-wide (auth, users, permissions, data, settings, operational overrides)

3) Eligibility and Ownership

- Owned by Chronix executive governance
- Maximum active Root Admin accounts: 2 (primary + emergency backup)
- Assignment requires dual approval (Platform Owner + Security/Operations approver)

4) Access Controls

- Mandatory MFA
- Strong password policy (14+ chars) and rotation policy
- No shared credentials
- Shorter session timeout than normal users
- Step-up verification for new devices/locations
- Optional IP/network allowlisting

5) Break-Glass Usage Rules

Allowed: incident response, lockout recovery, critical permissions repair, data integrity emergencies, outage remediation.

Not allowed: routine finance/ticket/project operations or convenience access replacing proper role assignment.

6) Impersonation Standard

- Root Admin may act as another role/user for troubleshooting
- UI must show persistent “Impersonation Active” banner

- Logs must include real actor and impersonated identity

7) Audit and Logging Requirements

- Log actor UID/email, action type, target resource, timestamp
- For writes: before/after snapshot
- Reason/comment required for destructive actions
- Store request metadata (IP/user-agent where available)
- Retention minimum 12 months (recommended 24+)

8) Sensitive Action Controls

- Step-up confirmation for destructive/bulk actions
- Optional second approver for high-impact operations
- Prefer soft-delete when feasible

9) Provisioning and Deprovisioning

- Provision outside normal user-creation flow
- Require documented ticket and approvals
- Immediate deprovision on misuse or security concern
- Test emergency revocation process quarterly

10) Backend Enforcement Principles

- Use explicit `isRootAdmin()` checks in rules/server guards
- Scope privileged bypass to controlled paths
- Preserve audit-write requirements for privileged actions
- Never rely on UI-only checks

11) Operational Safeguards

- Quarterly access review of Root Admin accounts
- Monthly review of Root Admin audit events
- Alerting for new device/location, bulk edits, destructive actions, after-hours break-glass use

12) Incident Response for Misuse

1. Revoke sessions/tokens immediately
2. Disable affected account(s)
3. Preserve audit logs

4. Run impact analysis and rollback where possible
5. Reissue access only after formal review

13) Implementation Acceptance Checklist

- ☐ Role added to role model and resolver
- ☐ Firestore/server checks updated and tested
- ☐ MFA enforced
- ☐ Audit logging complete for privileged actions
- ☐ Impersonation controls labeled and logged
- ☐ Emergency revoke procedure documented
- ☐ Governance owners assigned